

IoT-তে নিরাপত্তা (Security in IoT)

শিক্ষামূলক স্লাইডের সহজ ও সংক্ষিপ্ত বাংলা সারাংশ (Summary)

এই ডকুমেন্টটি IoT ডিভাইস ও নেটওয়ার্ককে কীভাবে সুরক্ষিত রাখা যায়, তার বিভিন্ন দিক ও প্রযুক্তি নিয়ে আলোচনা করেছে। নিচে মূল পয়েন্টগুলো সহজ ভাষায় তুলে ধরা হলো।

১. IoT নিরাপত্তা কেন আলাদা?

- সাধারণ কম্পিউটার বা স্মার্টফোনের মতো নয়, IoT ডিভাইসগুলো **সীমাবদ্ধ (Constrained)** – অর্থাৎ এদের মেমোরি, প্রসেসিং ক্ষমতা এবং ব্যাটারি খুবই কম।
- TCP/IP-তে ব্যবহৃত ঐতিহ্যবাহী নিরাপত্তা সমাধান (যেমন: অ্যান্টিভাইরাস, ফায়ারওয়াল) IoT-তে সরাসরি কাজ করে না, কারণ সেগুলো বেশি জায়গা ও শক্তি খরচ করে।
- তাই, IoT-এর জন্য **হালকা ও কার্যকরী** নিরাপত্তা ব্যবস্থা প্রয়োজন।

২. নিরাপত্তার মৌলিক চাহিদাগুলো (Security Requirements)

একটি ভালো নিরাপত্তা ব্যবস্থায় নিচের বিষয়গুলো নিশ্চিত করতে হয়:

- গোপনীয়তা (Confidentiality):** অননুমোদিত কেউ যেন ডেটা দেখতে না পায়।
- অখণ্ডতা (Integrity):** ডেটা পাঠানোর সময় যেন পরিবর্তন না হয়।
- উপলব্ধতা (Availability):** প্রামাণ্য ব্যবহারকারী যেন সবসময় ডেটা বা সার্ভিস পায় (DoS আক্রমণ থেকে বাঁচা)।
- প্রমাণীকরণ (Authentication):** নিশ্চিত করা যে ব্যবহারকারী বা ডিভাইসটি আসলেই সেই ব্যক্তি/ডিভাইস যাকে বলা হচ্ছে।
- অস্বীকার না করা (Non-repudiation):** কেউ যেন পরে বলে না যে "আমি এই ডেটা পাঠাইনি" বা "আমি পাইনি"।
- সহনশীলতা (Resilience):** আক্রমণের পরও দ্রুত স্বাভাবিক অবস্থায় ফিরে আসার ক্ষমতা।

৩. সাধারণ সাইবার আক্রমণগুলোর ধরন (Common Security Attacks)

আক্রমণের নাম	কী ঘটে?
স্নুপিং (Snooping)	অননুমোদিত ব্যক্তি ডেটা আটকিয়ে পড়ে ফেলে।
ট্রাফিক অ্যানালাইসিস	ট্রাফিক মনিটর করে গুরুত্বপূর্ণ তথ্য বের করা (যেমন: কে কার সাথে কতক্ষণ কথা বলছে)।
মডিফিকেশন	ডেটা পাঠানোর পথে তাতে পরিবর্তন করে দেওয়া।
মাস্কয়ারেডিং/স্পুফিং	নিজেকে অন্য কেউ হিসেবে চিহ্নিত করা (যেমন: হ্যাকার নিজেকে রাউটার হিসেবে পরিচয় দেয়)।
রিপ্লে অ্যাটাক	পুরনো একটি বৈধ বার্তা আবার পাঠিয়ে দেওয়া (যেমন: "দরজা খোল" কমান্ডটি বারবার পাঠানো)।
রিপুডিয়েশন	পাঠক বা গ্রহীতা পরে বলে যে তারা ডেটা পাঠাইনি বা পায়নি।
DoS (Denial of Service)	নেটওয়ার্ক বা সার্ভিসকে এত বেশি রিকোয়েস্ট দিয়ে অচল করে দেওয়া।

৪. ক্রিপ্টোগ্রাফি (Cryptography) – ডেটা লুকানোর কৌশল

ডেটা সুরক্ষিত রাখতে ক্রিপ্টোগ্রাফি ব্যবহার করা হয়। এটি দুই ধরনের:

- **সিমেট্রিক কী (Symmetric Key):** একটি গোপন চাবি (Key) দিয়ে ডেটা এনক্রিপ্ট ও ডিক্রিপ্ট করা হয়। পাঠক ও গ্রহীতা উভয়ের কাছে একই চাবি থাকে।
উদাহরণ: AES, DES।
ব্যবহার: দ্রুত এবং কম শক্তি খরচ করে, তাই IoT-তে বেশি ব্যবহৃত হয়।
- **অ্যাসিমেট্রিক কী (Asymmetric Key):** দুটি চাবি থাকে – পাবলিক কী (সবার জানা) এবং প্রাইভেট কী (শুধু মালিকের কাছে)। এক দিয়ে এনক্রিপ্ট করলে অন্য দিয়ে ডিক্রিপ্ট করতে হয়।
উদাহরণ: RSA, ECC (Elliptic Curve Cryptography)।
ব্যবহার: ধীর এবং বেশি শক্তি খরচ করে, তবে ডিজিটাল সিনেচারের জন্য ভালো।

৫. মেসেজ ইনটিগ্রিটি ও অথেনটিসিটি (Message Integrity & Authenticity)

- **ইনটিগ্রিটি চেক:** ডেটা অপরিবর্তিত আছে কিনা তা যাচাই করতে **হ্যাশ ফাংশন** ব্যবহার করা হয়। ডেটা থেকে একটি ছোট ফিঙ্গারপ্রিন্ট (Message Digest) বের করা হয়। ডেটা পরিবর্তন হলেই এই ফিঙ্গারপ্রিন্ট পরিবর্তন হয়।
জনপ্রিয় হ্যাশ: MD5, SHA-1 (বর্তমানে পুরনো), SHA-256।
- **অথেনটিসিটি চেক (MAC):** ডেটা আসলেই নির্দিষ্ট প্রেরকের কাছ থেকে এসেছে কিনা তা নিশ্চিত করতে **Message Authentication Code (MAC)** ব্যবহার করা হয়। এটি তৈরি করতে একটি গোপন চাবি এবং হ্যাশ ফাংশন একসাথে

ব্যবহার করা হয়। (লক্ষ্য করুন: এখানে MAC মানে Message Authentication Code, নেটওয়ার্কের MAC Address নয়)।

৬. ডিজিটাল সিগনেচার ও PKI (Digital Signature & PKI)

- ডিজিটাল সিগনেচার হলো অ্যাসিমেট্রিক ক্রিপ্টোগ্রাফি ব্যবহার করে তৈরি একটি ইলেকট্রনিক স্বাক্ষর। এটি নিশ্চিত করে যে ডেটা নির্দিষ্ট ব্যক্তির কাছ থেকে এসেছে এবং তা পরিবর্তন করা হয়নি।
- কিন্তু, পাবলিক কীটি আসলেই ওই ব্যক্তির কিনা তা কীভাবে বুঝব? এর জন্য আছে **PKI (Public Key Infrastructure)**। এটি একটি **সার্টিফিকেট অথরিটি (CA)** দিয়ে নিশ্চিত করে যে পাবলিক কীটি আসল এবং বিশ্বস্ত।

৭. এন্ড-পয়েন্ট অথেনটিকেশন (End-Point Authentication)

এটি নিশ্চিত করে যে নেটওয়ার্কের অপর পাশে যার সাথে কথা বলা হচ্ছে, তিনি সত্যিই "লাইভ" এবং তিনি যাকে চিনছেন তিনি-ই। সাধারণ পাসওয়ার্ড স্ক্রিপিং বা রিলে অ্যাটাকের ঝুঁকিতে থাকে। সমাধান হিসেবে **ননস (Nonce)** – যা একবার ব্যবহারের জন্য তৈরি একটি র্যান্ডম নম্বর – ব্যবহার করা হয়, যাতে পুরনো বার্তা আবার কাজ না করে।

৮. IoT-তে লেয়ার-ভিত্তিক নিরাপত্তা (Layer-wise Security)

ক) ফিজিক্যাল ও MAC লেয়ার (IEEE 802.15.4)

- এই লেয়ারগুলোতে **AES-128** এনক্রিপশন হার্ডওয়্যারেই (চিপের ভিতরেই) দেওয়া থাকে, যা কম শক্তিতে দ্রুত কাজ করে।
- বিভিন্ন সিকিউরিটি মোড:
 - **AES-CTR**: শুধু গোপনীয়তা (Encryption) দেয়।
 - **AES-CBC-MAC**: শুধু ডেটা অথেনটিসিটি ও ইনটিগ্রিটি দেয় (MAC তৈরি করে)।
 - **AES-CCM**: গোপনীয়তা + অথেনটিসিটি + ইনটিগ্রিটি – সবকিছু একসাথে দেয়। (এটি সবচেয়ে বেশি ব্যবহৃত)।
- **রিলে অ্যাটাক** থেকে বাঁচতে প্রতিটি প্যাকেটে একটি **ফ্রেম কাউন্টার (Frame Counter)** ব্যবহার করা হয়, যা প্রতি বার্তায় বাড়তে থাকে।

খ) নেটওয়ার্ক লেয়ার (6LoWPAN ও RPL)

- **6LoWPAN**: এই লেয়ারে সরাসরি কোনো নিরাপত্তা ব্যবস্থা নেই, তবে নিচের (MAC) লেয়ারের AES-CCM ব্যবহার করার পরামর্শ দেওয়া হয়।
- **RPL (Routing Protocol)**: এই রাউটিং প্রোটোকলে তিনটি নিরাপত্তা মোড আছে:
 1. **Unsecured**: কোনো নিরাপত্তা নেই।
 2. **Preinstalled**: একটি পূর্ব-নির্ধারিত চাবি দিয়ে সব যোগাযোগ সুরক্ষিত।
 3. **Authenticated**: প্রথমে একটি সাধারণ চাবি দিয়ে নেটওয়ার্কে ঢুকে পরে একটি বিশেষ কর্তৃপক্ষের (Key Authority) কাছ থেকে নতুন চাবি নিয়ে নেটওয়ার্কের অংশ হয়।

গ) অ্যাপ্লিকেশন লেয়ার (CoAP)

- CoAP হলো IoT-তে ব্যবহৃত একটি হালকা যোগাযোগ প্রোটোকল।
- এটি **DTLS (Datagram TLS)** ব্যবহার করে নিরাপত্তা দেয়, যা UDP-র উপর কাজ করে।
- CoAP-এর চারটি নিরাপত্তা মোড:
 1. **NoSec:** কোনো নিরাপত্তা নেই (শুধু গবেষণার জন্য)।
 2. **PreSharedKey:** ডিভাইসগুলোতে আগে থেকেই একটি গোপন চাবি দেওয়া থাকে।
 3. **RawPublicKey:** ডিভাইসে একটি পাবলিক-প্রাইভেট কী জোড়া থাকে, কিন্তু সার্টিফিকেট থাকে না। ECC (Elliptic Curve Cryptography) ব্যবহার করে।
 4. **Certificates:** ডিভাইসে একটি X.509 সার্টিফিকেট থাকে, যা PKI-র মাধ্যমে যাচাই করা হয়।

৯. IoT-র জন্য বিশেষ নিরাপত্তা ব্যবস্থা (Security Mechanisms for IoT)

1. **হালকা ক্রিপ্টোগ্রাফি (Lightweight Cryptography):** যেহেতু IoT ডিভাইস দুর্বল, তাই তাদের জন্য হালকা অ্যালগরিদম তৈরি করা হয়েছে।
ব্লক সাইফার: PRESENT, PRINCEI
হ্যাশ ফাংশন: PHOTON, SPONGENTI
2. **সিকিউর হার্ডওয়্যার (PUF):** চিপ তৈরির সময় অতি-সূক্ষ্ম তারতম্যের কারণে প্রতিটি চিপের একটি অনন্য "ফিঙ্গারপ্রিন্ট" তৈরি হয়, যাকে বলা হয় **PUF (Physically Unclonable Function)**। এটি কপি করা যায় না, তাই ডিভাইস শনাক্তকরণে ব্যবহার হয়।
3. **ইনট্রুশন ডিটেকশন সিস্টেম (IDS):** IoT ডিভাইসে অ্যান্টিভাইরাস চালানো সম্ভব নয়, তাই হালকা IDS ব্যবহার করে CPU ব্যবহার, মেমোরি খরচ, বা ট্রাফিকের অস্বাভাবিকতা খুঁজে বের করে আক্রমণ শনাক্ত করা হয়।

শেষ কথা (সংক্ষিপ্ত উপসংহার)

IoT নিরাপত্তা একটি চ্যালেঞ্জিং কাজ, কারণ ডিভাইসগুলো সীমিত সম্পদের (Memory, Power) উপর চলে। এনক্রিপশন (AES-CCM) এবং প্রমাণীকরণ (MAC) হলো IoT নিরাপত্তার ভিত্তি। নেটওয়ার্কের প্রতিটি স্তরেই (PHY, MAC, Network, Transport, Application) আলাদা করে নিরাপত্তা নিশ্চিত করতে হয়। DTLS এবং হালকা ক্রিপ্টোগ্রাফি IoT-র জন্য তৈরি বিশেষ সমাধান। ভবিষ্যতে IoT-তে কৃত্রিম বুদ্ধিমত্তা (AI) ভিত্তিক নিরাপত্তা এবং ব্লকচেইন প্রযুক্তি আরও গুরুত্বপূর্ণ হয়ে উঠবে।